

REPORT M3

METASPLOITABLE



RIEPILOGO

Report sulle vulnerabilità rilevate tramite scansione con Nessus sulla macchina Metasploitable, analisi primaria, attuazione delle soluzioni alle criticità e analisi con risoluzione della criticità. Verrà elencato tramite l'uso di grafici o immagini il processo di analisi risoluzione e analisti post risoluzione, verranno risolte solo alcune criticità gravi e non tutte. Il report sarà stilato in maniera pressoché tecnica.

SCANSIONE INIZIALE

AVVIO DELLA SCANSIONE PRIMARIA TRAMITE NESSUS

192.168.1.17



Host Information

Netbios Name: METASPLOITABLE
IP: 192.168.1.17
MAC Address: 08:00:27:DE:12:21
OS: Linux Kernel 2.6 on Ubuntu 8.04 (hardy)

La scansione primaria effettuata utilizzando Nessus al IP 192.168.1.17 che è l'indirizzo IPv4 Assegnato a Metasploitable

Le 4 vulnerabilità scelte sono:

- 1) 51988 - Bind Shell BackDoor Detection
- 2) 11356 - NFS Exported Share Information Disclosure
- 3) 61708 - VNC Server 'password' password
- 4) 90509 - Samba Badlock Vulnerability

BIND SHELL BACKDOOR DETECTION

LA PRIMA VULNERABILITÀ
PRESA IN CONSIDERAZIONE È
QUELLA CHE NESSUS NUMERA
COME 51988.

Descrizione :

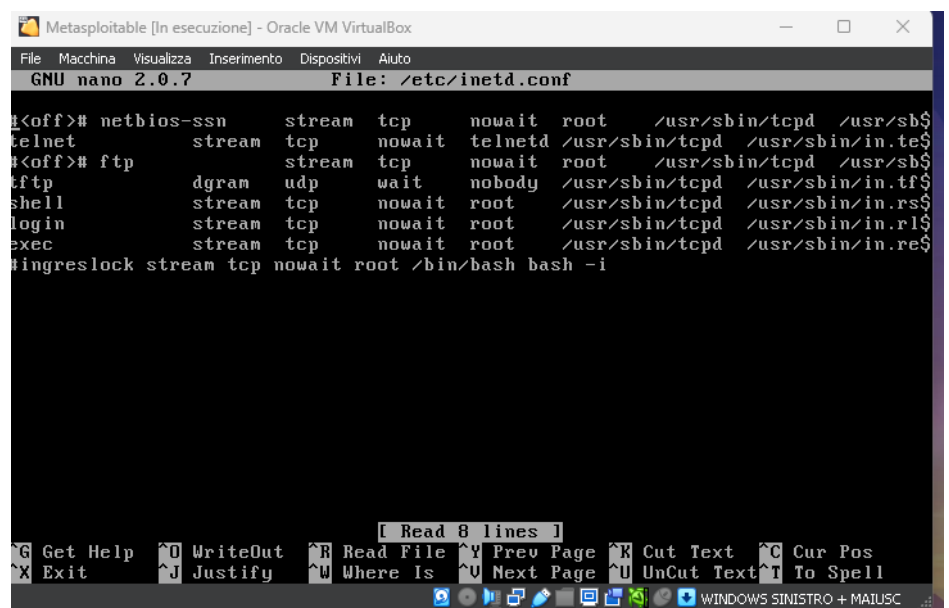
La Shell è in ascolto sulla porta remota senza chiedere prima alcuna autenticazione. Un utente malintenzionato può accedere alla porta in remoto ed eseguire comandi.

Soluzione di Nessus:

Verificare se l'Host è stato manomesso da remoto e, se necessario, reinstalla il sistema.

La soluzione attuata:

Dopo aver verificato che l'Host non sia stato compromesso ho aggiunto un commento nel file di configurazione contenuto in /etc/inetd.conf tramite comando "sudo nano /etc/inetd.conf" andando a commentare o eliminare la riga di codice dell'esecuzione della bind shell. Nel caso in cui il servizio sia utilizzato è opportuno aggiungere un'autenticazione all'accesso remoto.



The screenshot shows a terminal window titled "Metasploitable [In esecuzione] - Oracle VM VirtualBox". Inside the terminal, the GNU nano 2.0.7 text editor is open, editing the file /etc/inetd.conf. The file contains a table of services and their configurations. The 'shell' service is highlighted with a red cursor. The table lists services like netbios-ssn, telnet, ftp, shell, login, exec, and xingreslock, along with their protocols, wait status, user, and command.

Service	Protocol	Wait	User	Command
netbios-ssn	stream	tcp	nowait	root /usr/sbin/tcpd /usr/sbin/in.telnetd
telnet	stream	tcp	nowait	root /usr/sbin/tcpd /usr/sbin/in.telnetd
ftp	stream	tcp	nowait	root /usr/sbin/tcpd /usr/sbin/in.ftpd
shell	dgram	udp	wait	nobody /usr/sbin/tcpd /usr/sbin/in.rshd
login	stream	tcp	nowait	root /usr/sbin/tcpd /usr/sbin/in.rlogind
exec	stream	tcp	nowait	root /usr/sbin/tcpd /usr/sbin/in.rexecd
xingreslock	stream	tcp	nowait	root /bin/bash bash -i

NFS EXPORTED SHARE INFORMATION DISCLOSURE

**LA SECONDA VULNERABILITÀ
PRESA IN CONSIDERAZIONE È
QUELLA CHE NESSUS NUMERA
COME 11356.**

Descrizione :

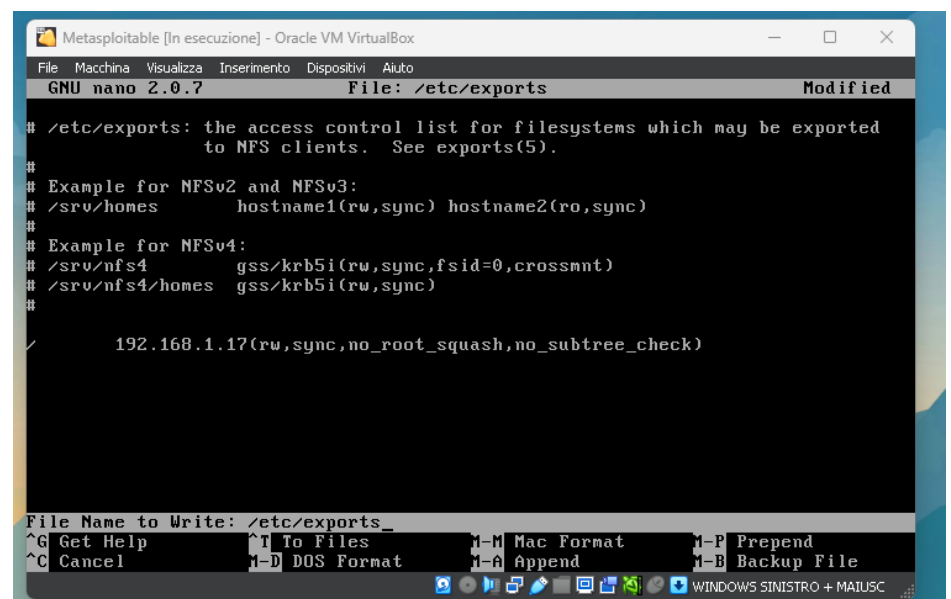
E' presente almeno una delle condivisioni NFS esportate dal server remoto che potrebbe essere montata dall'host che esegue la scansione. Un attaccante potrebbe prenderne vantaggio per leggere (e potenzialmente scrivere) file sull'host remoto.

Soluzione di Nessus:

Configurare NSF sul host remoto in modo che solo gli host autorizzati possano montare connessioni remote.

La soluzione attuata:

Per risolvere questo problema ho modificato il file Exports presente nella cartella etc aggiungendo l'ip di metasploitable2 alla lista degli utenti autorizzati.



The screenshot shows a terminal window titled 'Metasploitable [In esecuzione] - Oracle VM VirtualBox'. The window displays the contents of the `/etc/exports` file being edited with the `nano` text editor. The file content includes comments and examples for NFSv2, NFSv3, and NFSv4, followed by a line for `192.168.1.17` with options `(rw,sync,no_root_squash,no_subtree_check)`. The terminal window has a menu bar with 'File', 'Macchina', 'Visualizza', 'Inserimento', 'Dispositivi', and 'Aiuto'. At the bottom, there is a status bar with 'File Name to Write: /etc/exports_' and a row of keyboard shortcuts: '^G Get Help', '^I To Files', 'M-M Mac Format', 'M-P Prepend', '^C Cancel', 'M-D DOS Format', 'M-A Append', and 'M-B Backup File'. The bottom right corner of the window shows the system tray with icons for network, volume, and power, along with the text 'WINDOWS SINISTRO + MAIUSC'.

```
Metasploitable [In esecuzione] - Oracle VM VirtualBox
File  Macchina  Visualizza  Inserimento  Dispositivi  Aiuto
GNU nano 2.0.7      File: /etc/exports      Modified

# /etc/exports: the access control list for filesystems which may be exported
# to NFS clients.  See exports(5).
#
# Example for NFSv2 and NFSv3:
# /srv/homes          hostname1(rw,sync) hostname2(ro,sync)
#
# Example for NFSv4:
# /srv/nfs4           gss/krb5i(rw,sync,fsid=0,crossmnt)
# /srv/nfs4/homes     gss/krb5i(rw,sync)
#
192.168.1.17(rw,sync,no_root_squash,no_subtree_check)

File Name to Write: /etc/exports_
^G Get Help      ^I To Files      M-M Mac Format   M-P Prepend
^C Cancel        M-D DOS Format   M-A Append       M-B Backup File
WINDOWS SINISTRO + MAIUSC
```

VNC SERVER 'PASSWORD' PASSWORD

LA TERZA VULNERABILITÀ
PRESA IN CONSIDERAZIONE È
QUELLA CHE NESSUS NUMERA
COME 61708.

Descrizione :

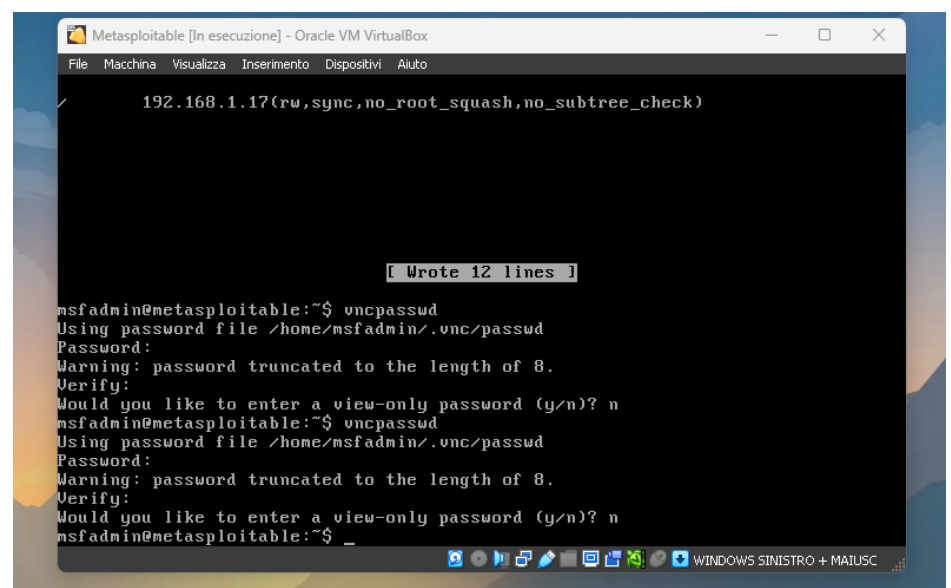
Il server VNC in esecuzione sull'host remoto è protetto da una password debole. Nessus è stato in grado di effettuare il login utilizzando l'autenticazione una password di tipo "password". Un attaccante remoto non autenticato potrebbe sfruttare questo exploit per prendere il controllo del sistema.

Soluzione di Nessus:

Mettere in sicurezza il server VNC con una password "Forte"

La soluzione attuata:

Andiamo a cambiare la password in una più complessa, nel mio caso "Peppe124".



```
Metasploitable [In esecuzione] - Oracle VM VirtualBox
File  Macchina  Visualizza  Inserimento  Dispositivi  Aiuto

192.168.1.17(rw, sync, no_root_squash, no_subtree_check)

[ Wrote 12 lines ]

msfadmin@metasploitable:~$ vncpasswd
Using password file /home/msfadmin/.vnc/passwd
Password:
Warning: password truncated to the length of 8.
Verify:
Would you like to enter a view-only password (y/n)? n
msfadmin@metasploitable:~$ vncpasswd
Using password file /home/msfadmin/.vnc/passwd
Password:
Warning: password truncated to the length of 8.
Verify:
Would you like to enter a view-only password (y/n)? n
msfadmin@metasploitable:~$ _
```

UPDATE THE AJP CONFIGURATION TO REQ AUTH

LA QUARTA VULNERABILITÀ
PRESA IN CONSIDERAZIONE È
QUELLA CHE NESSUS NUMERA
COME 134862.

Descrizione :

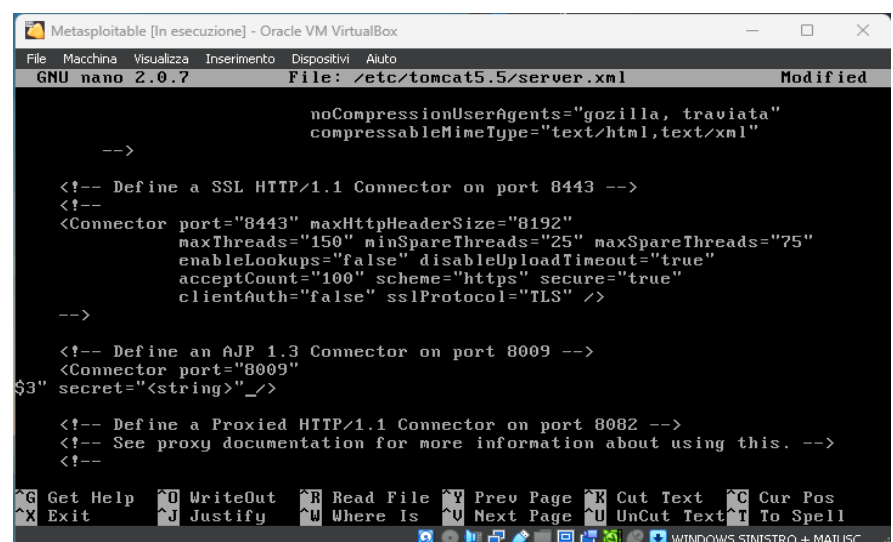
Una vulnerabilità di lettura/inclusione dei file è stata trovata nel connettore AJP. Un malintenzionato remoto e non autenticato potrebbe sfruttare questa vulnerabilità per leggere i file delle applicazioni web da un server vulnerabile. Nei casi in cui il server vulnerabile consente il caricamento di file, un utente malintenzionato potrebbe caricare il codice JavaServer Pages (JSP) dannoso all'interno di una varietà di tipi di file e ottenere l'esecuzione di codice remoto (RCE).

Soluzione di Nessus:

Aggiorna la configurazione AJP per richiedere l'autorizzazione e/o aggiorna Tomcat alle versioni 7.0.100, 8.5.51, 9.0.31 o Successive.

La soluzione attuata:

Per abilitare il connettore Apache AJP in modo sicuro e garantire un'adeguata protezione, è necessario apportare modifiche al file server.xml, che si trova tipicamente in /etc/tomcat5.5 aggiungendo alla riga del Connettore AJP: che tipicamente è identificata da un tag <Connector> con un attributo port="8009" Vicino a questo tag, le seguenti stringhe: secret="<string>"



```
Metasploitable [In esecuzione] - Oracle VM VirtualBox
File Macchina Visualizza Inserimento Dispositivi Aiuto
GNU nano 2.0.7 File: /etc/tomcat5.5/server.xml Modified

noCompressionUserAgents="gozilla, traviata"
compressableMimeType="text/html,text/xml"

-->

<!-- Define a SSL HTTP/1.1 Connector on port 8443 -->
<!--
<Connector port="8443" maxHttpHeaderSize="8192"
maxThreads="150" minSpareThreads="25" maxSpareThreads="75"
enableLookups="false" disableUploadTimeout="true"
acceptCount="100" scheme="https" secure="true"
clientAuth="false" sslProtocol="TLS" />

-->

<!-- Define an AJP 1.3 Connector on port 8009 -->
<Connector port="8009"
$3" secret="<string>" />

<!-- Define a Proxyed HTTP/1.1 Connector on port 8082 -->
<!-- See proxy documentation for more information about using this. -->
<!--

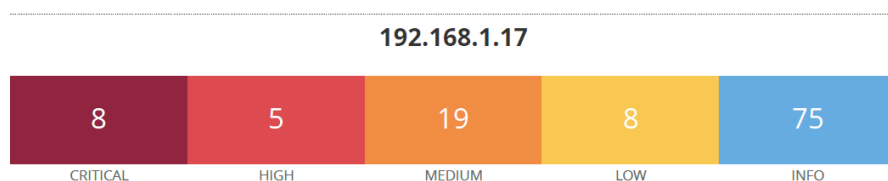
^G Get Help ^O WriteOut ^R Read File ^V Prev Page ^X Cut Text ^C Cur Pos
^X Exit ^J Justify ^W Where Is ^U Next Page ^U UnCut Text ^T To Spell
WINDOWS SINISTRO + MAIUSC
```



SCANSIONE FINALE

AVVIO DELLA SCANSIONE CON CORREZIONI APPORTATE TRAMITE NESSUS

La scansione effettuata utilizzando Nessus al IP 192.168.1.17 che è l'indirizzo IPv4 Assegnato a Metasploitable



Come si evince dal grafico in alto possiamo vedere che le modifiche attuate risolvono le problematiche da noi designate e non vengono segnate nel report di Nessus

REALIZZATA DA GIUSEPPE FEDERICO